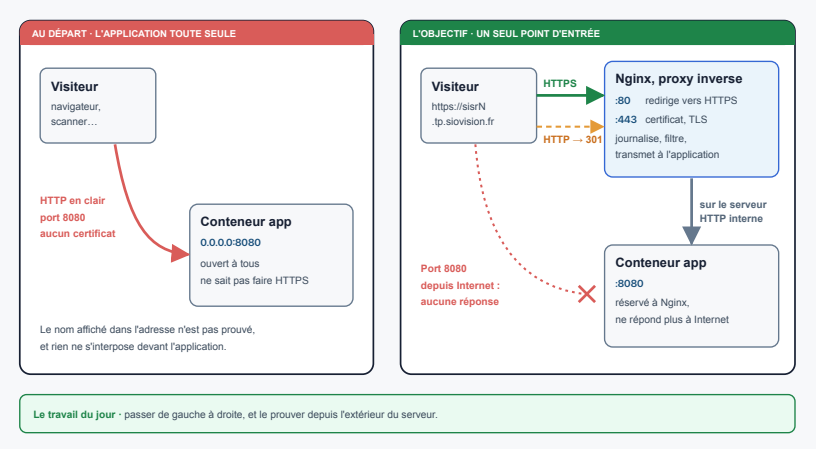
Publier un service sans l'exposer

Conteneur, proxy inverse, HTTPS et port fermé



Document
BTS SIO 2e année
SISR

Portée
Transversale

Thème
Service web exposé sur Internet

Objectifs

- **Publier** en HTTPS une application qui ne sait pas le faire.
- **Vérifier** ce qui est réellement joignable depuis Internet.
- **Fermer** un port exposé, et **expliquer** ce qui l'a fermé.

Prérequis : votre clé SSH, adresse et port, certificat. Absent le 3/11 : la fiche P07 sert de guide pour le certificat.

On vous livre une application. Vous en faites quoi ?

Un éditeur vous donne un programme prêt à lancer. Il répond en HTTP, sur le port 8080.

Il ne connaît pas	Il ne fait pas
Votre nom de domaine	HTTPS, ni certificat
Vos visiteurs	Le tri des requêtes
Internet et ses scanners	Votre protection

Le lancer sur un serveur public, c'est facile. **Le mettre en service, c'est autre chose.**

Un conteneur : le programme et ce qu'il lui faut

Comme un conteneur maritime : on ne regarde pas dedans, on le pose et on branche.

	Machine virtuelle	Conteneur
Contient	Un système complet	L'application et ses dépendances
Démarrage	En minutes	En secondes
Isolation	Forte, un système par VM	Partage le noyau du serveur
Vous l'utilisez	Proxmox, cloud	`docker run`

Aujourd'hui, Docker reste une boîte fournie. Compose, volumes et secrets viendront plus tard.

Rappel : d'où vient le cadenas ?

Question	Réponse vue en P07
Que lie un certificat ?	Une clé publique à un nom, sous la signature d'une autorité
Comment Let's Encrypt vous croit-il ?	Il vient lire un jeton sur le port 80 de votre serveur
Où reste la clé privée ?	Sur le serveur, elle ne voyage jamais
Pourquoi pas d'alerte du navigateur ?	L'autorité est déjà connue de tous les postes

Absent le 3/11 ? Tout est dans la fiche P07, et vous repartez d'un serveur neuf comme les autres.

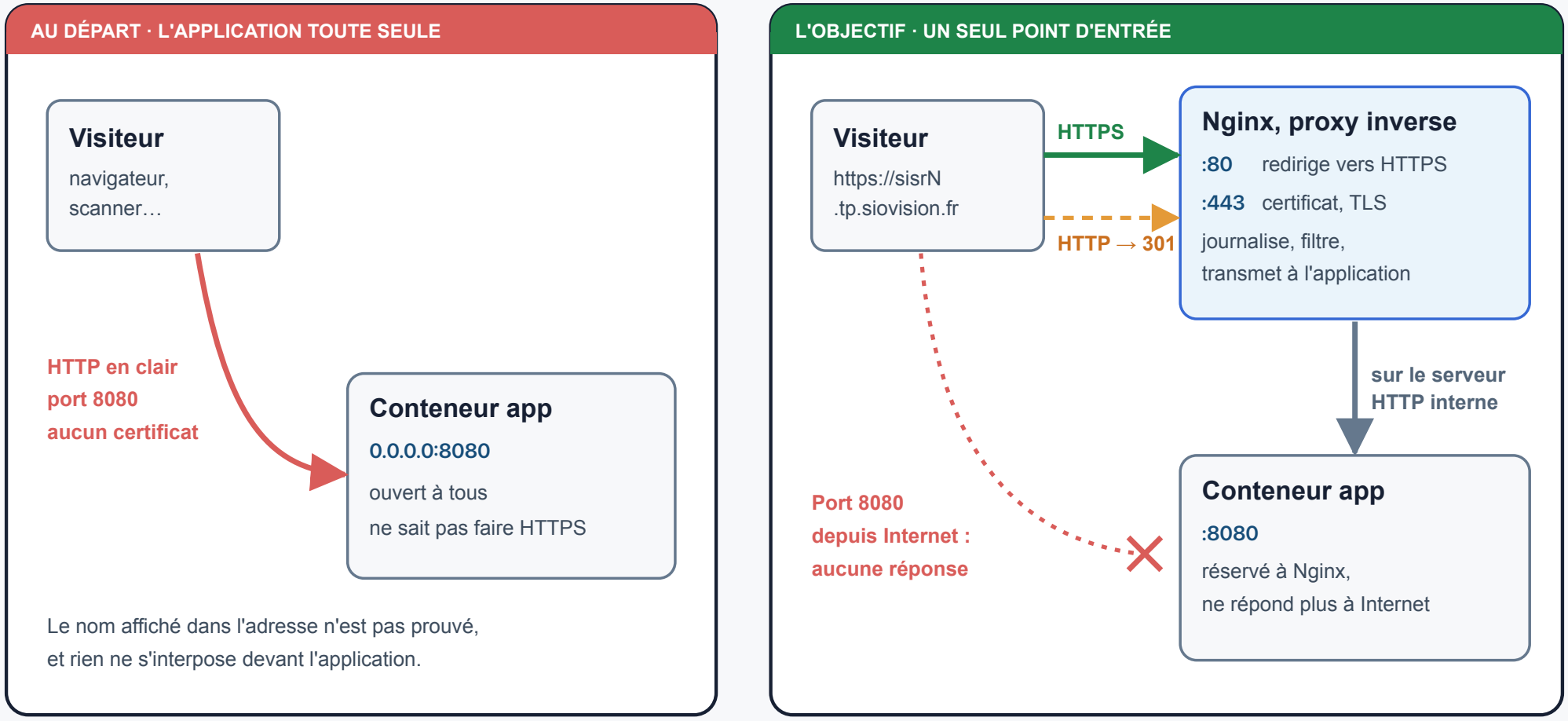
Le proxy inverse : l'accueil de l'immeuble

Personne ne monte directement dans les bureaux : on passe par l'accueil, qui oriente.

Ce qu'il centralise	Ce que ça change
Un seul point d'entrée	L'application n'a plus à être exposée
Le certificat et TLS	Un seul endroit à gérer et à renouveler
Les journaux	On sait qui a demandé quoi
Le filtrage et la charge	Protection et répartition possibles devant l'application

Produits courants : Nginx, HAProxy, Traefik, Caddy.

Le travail du jour



Le travail du jour · passer de gauche à droite, et le prouver depuis l'extérieur du serveur.

Fermer un port : deux leviers

	L'adresse d'écoute	Le pare-feu (nftables)
Question posée	Sur quelle porte le service attend-il ?	Quels paquets laisse-t-on passer ?
Où ça se règle	Dans le service	Dans le noyau du serveur
Exemple	`0.0.0.0` : partout ; `127.0.0.1` : en local	`policy drop`, puis ce qui est autorisé
Comment l'observer	`ss -ltnp`	`nft list ruleset`

Vous allez prévoir, tester, puis expliquer ce que vous observez.

ATTENTION

Un pare-feu peut vous enfermer dehors

Ce serveur est sur Internet, et une règle fausse coupe aussi votre SSH.

- **Avant toute règle :** programmer le filet de sécurité, qui annule tout au bout de cinq minutes.
- **Un test ne vaut que depuis l'extérieur :** depuis le serveur lui-même, il ne prouve rien.
- **Ce qui « devrait » marcher n'est pas une preuve :** on regarde ce qui répond vraiment.

Ce qu’on cherche à apprendre

	Ce que vous saurez	À quoi ça sert
Un modèle	Suivre le trajet d’une requête, du navigateur à l’application	Raisonner sur Nginx, Stormshield, n’importe quel équipement
Un geste	Configurer, valider, recharger, vérifier	Le quotidien d’un administrateur
Une méthode	Observé, attendu, hypothèse, test	Dépanner sans changer dix choses au hasard

Les commandes s’oublient et se retrouvent. **Le raisonnement, c’est ce qui reste.**

À quoi ça sert pour le BTS ?

Épreuve	Ce qu'on y demande	Ce que vous faites aujourd'hui
E7, écrit	Écrire la configuration d'un proxy inverse	Vous l'écrivez et elle tourne
E7, écrit	Justifier des choix de certificats et de chiffrement TLS	Vous gérez un vrai certificat
E7, écrit	Écrire des règles : source, destination, port, décision	Matrice des flux, question 9
E6, portfolio	Prouver un accès sécurisé à un service	Vos tests sont déjà des preuves

À l'écrit, on vous demandera de **justifier**, pas de réciter.

À RETENIR

Comment on saura que c'est réussi

Je testerai votre serveur depuis l'extérieur, en fin de séance, devant tout le monde :

Test	Attendu
`https://sisrN.tp.siovision.fr/`	La page avec `Name: sisrN`, sans alerte
`http://sisrN.tp.siovision.fr/`	Redirection `301` vers HTTPS
`http://sisrN.tp.siovision.fr:8080/`	Aucune réponse de l'application

Et il faudra **expliquer sans notes** le chemin d'une requête.

ACTIVITÉ

Et maintenant, à vous

Sur ordinateur · individuel · un serveur chacun · jusqu'à la restitution

À produire : les trois tests réussis, et vos preuves commande / attendu / observé / conclusion.

1. **Démarrer :** fiche P08 sur le site, étapes 1 et 2 : serveur neuf et application lancée.
2. **Problème 1 :** HTTPS par le proxy inverse.
3. **Problème 2 :** fermer le port 8080. Notez votre prévision avant de tester.